

× × × ×

FINSECURE BANK ISO/IEC 27001 INTERNAL AUDIT REPORT

JUNE 2026



Visit Our Website

www.finsecurebank.com



KEERTENNAH DEVI A/P PONNAMBALAM (MEC254026)

GROUP AUDIT TEAMS



KEERTENNAH DEVI

Lead Auditor

Overall audit management, scoping, BNM RMiT compliance oversight and final reporting



LILIAN

Technical Auditor

Evaluation of Cloud infrastructure security, mobile/web app vulnerabilities and technical access controls



NETHRA

Compliance Auditor

Review of supplier contracts, risk assessment frameworks, policy documentation and operational records

Audit Scope & Prepration

About FinSecure Bank: A mid-sized digital banking institution operating exclusively within the highly regulated financial ecosystem of Malaysia.

Core Digital Ecosystem In-Scope:

- Online Banking (Web Platform)
- Mobile Banking Application
- Cloud-Based Customer Data Storage (AWS Infrastructure)
- Third-Party Payment Gateway Integrations (FPX / PayNet APIs)

Audit Objectives

- To evaluate FinSecure Bank's readiness for formal ISO/IEC 27001 certification.
- To assess compliance with mandatory ISO 27001 clauses (Clauses 4–10) and specific Annex A security controls
- To identify security gaps, operational vulnerabilities, and areas of non-conformity before the external certification audit.



Selected Checklist Section

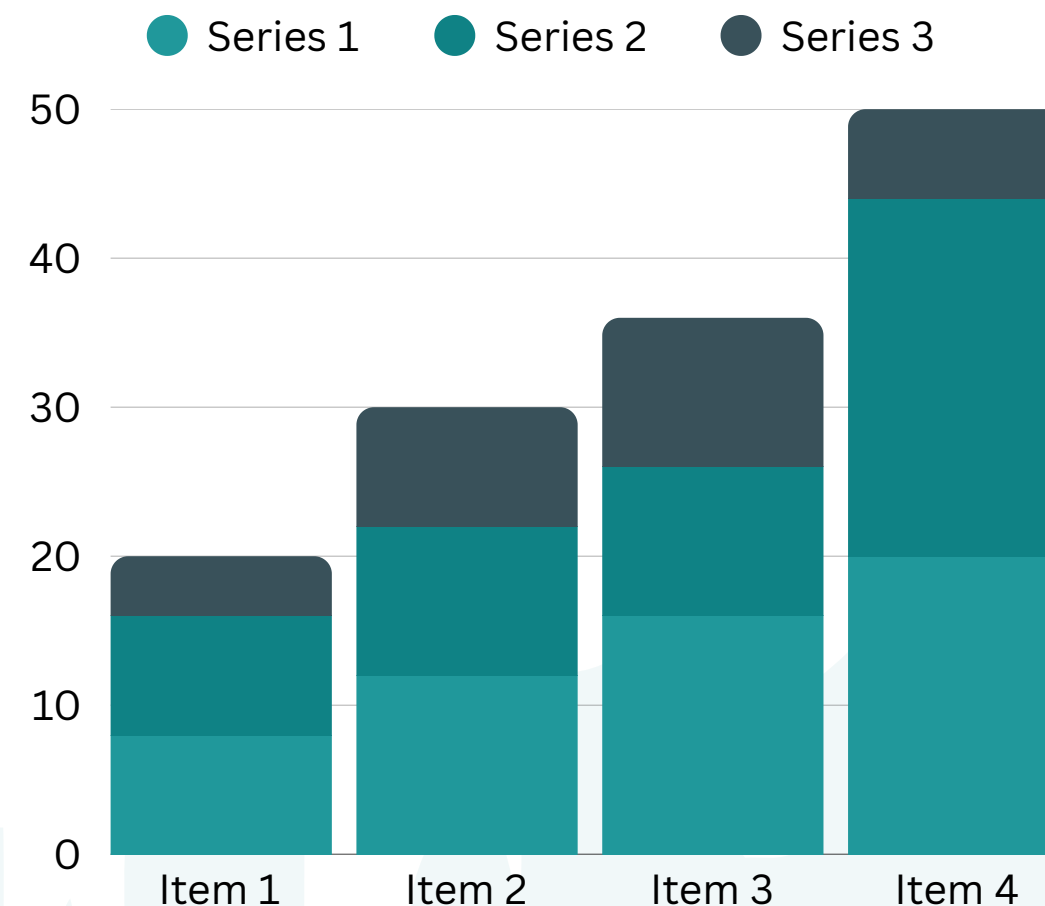
The audit targeted four critical risk domains:

1. **Risk Assessment (Clause 6.1.2 & 6.1.3):** Evaluating how information security risks are identified, analyzed, and treated.
2. **Access Control (Annex A.8.15 - A.8.18):** Reviewing user provisioning, multi-factor authentication, and privileged access management.
3. **Cloud Security (Annex A.5.23, A.8.10, A.8.22):** Reviewing data segregation, cloud configuration management, and storage security.
4. **Supplier Management (Annex A.5.19 - A.5.22):** Inspecting security requirements in third-party payment gateway SLAs and vendor contracts.



Audit Execution & Recommendations

The audit team executed testing through document reviews, technical configuration audits, and personnel interviews. The 5 core findings categorized by severity, mapped to ISO 27001 controls, and paired with immediate corrective actions.





Finding 1: MFA Failure

Classification: Major Non-Conformity

Issue: During a technical configuration review of the cloud environment hosting sensitive customer data, it was discovered that two root administrative accounts and three senior developer accounts did not have Multi-Factor Authentication (MFA) enforced. Access relied solely on single-factor passwords.



ISO Mapping: Annex A.8.5 (Secure Authentication)

Risk Impact: Critical risk of credential stuffing or brute-force attacks. If an administrative account is compromised, unauthorized entities could gain full access to the cloud backend, leading to massive customer data exfiltration, regulatory penalties from Bank Negara Malaysia and severe brand damage..

Corrective Actions: Mandate and enforce hardware or app-based MFA for all administrative and privileged cloud accounts immediately.

Preventive Control: Implement an automated Identity and Access Management (IAM) policy that blocks authentication attempts from accounts without active MFA.

Priority Level: High

Finding 2: Incomplete Third-Party Supplier Risk Assessments

Classification: Major Non-Conformity

Issue: The bank integrates with a new niche third-party payment gateway for cross-border transactions. However, there was no evidence of an information security risk assessment or a Right-to-Audit clause executed prior to signing the vendor contract..

ISO Mapping: Annex A.5.19 (Supplier Relationships) Clause 6.1.2 (Information security risk assessment).

Risk Impact: The bank cannot guarantee that the payment gateway complies with baseline security practices. A breach at the vendor level could compromise FinSecure Bank's transactional data pipelines, resulting in financial fraud and supply-chain vulnerabilities.

Corrective Actions: Halt non-essential data transfers and issue a retroactive security questionnaire to the vendor, requiring proof of their ISO 27001 certification.

Preventive Control: Update the Procurement Policy to legally prohibit the onboarding of any third-party IT vendor without a completed Security Risk Assessment signed off by the CISO.

Priority Level: High



Finding 3: IAM Offboarding

Classification: Minor Non-Conformity

Issue: HR offboarding logs against active Active Directory accounts revealed that employees who resigned from the bank 30 to 45 days ago still possessed active network and web banking backend access credentials.

ISO Mapping: Annex A.7.6 (Termination Responsibilities)

Risk Impact: Medium risk of insider threat or unauthorized systems access. Former employees could potentially log in remotely to alter configurations or download internal data assets.

Corrective Actions: Deprovision and disable all identified stale user accounts immediately.

Preventive Control: Create a synchronized, automated workflow between the HR Management System and Active Directory so that marking an employee as "Terminated" automatically suspends all IT access keys of their final day.

Priority Level: Medium.



Finding 4: Data Classification

Classification: Minor Non-Conformity

Issue: AWS S3 buckets containing transaction logs lacked mandatory classification metadata tags.

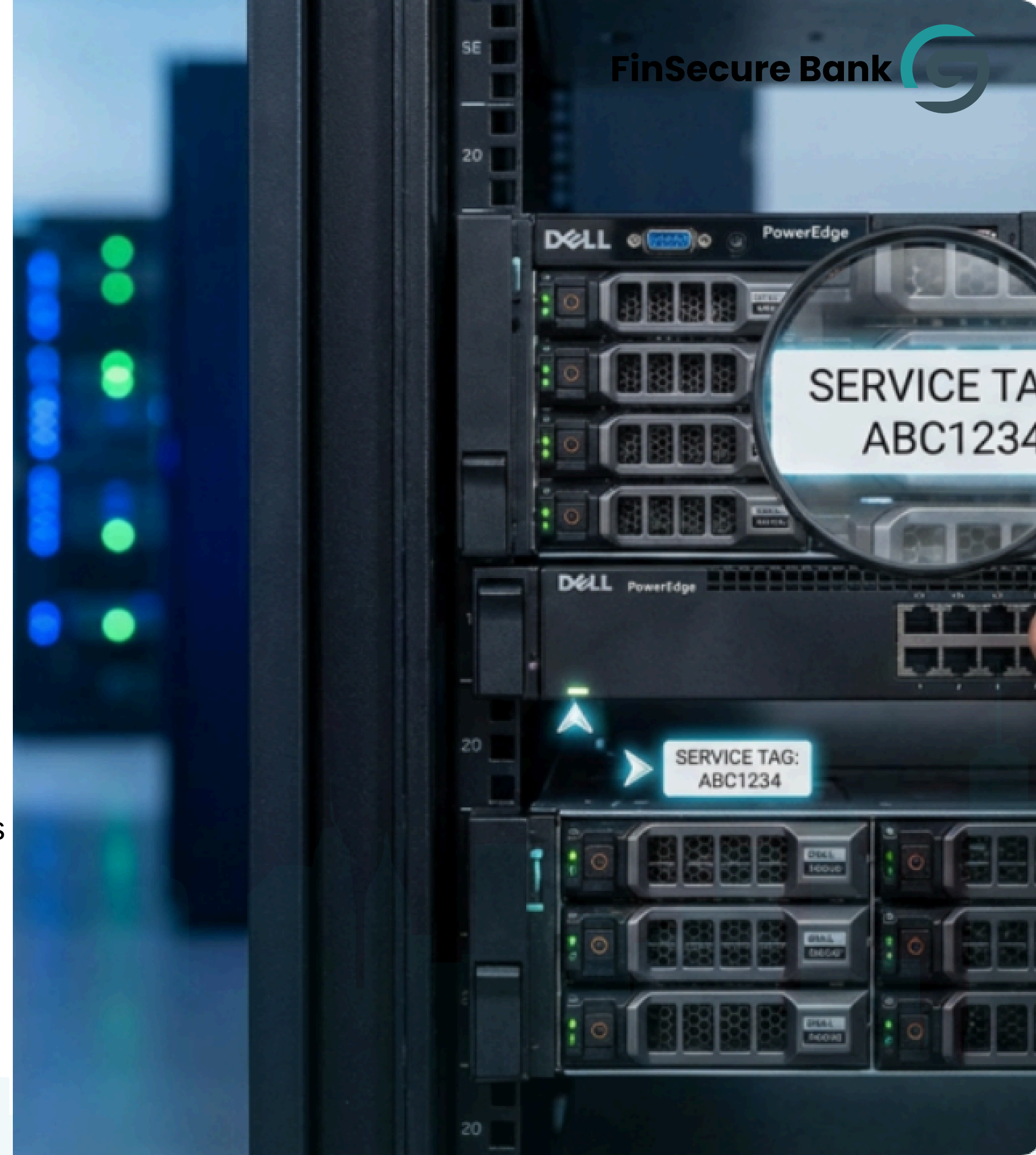
ISO Mapping: Annex A.5.12 (Classification of Information)

Risk Impact: Without explicit classification tags, automated data loss prevention (DLP) tools cannot accurately detect and prevent sensitive data leaks, increasing the probability of accidental public exposure.

Corrective Actions: Manually review and apply correct metadata classification tags to the identified cloud buckets.

Preventive Control: Deploy infrastructure-as-code (IaC) guardrails that automatically reject the creation of any new cloud storage asset if data classification tags are missing from the deployment script.

Priority Level: Medium.



Finding 5: Outdated Asset Register Review Cycle



Classification: Observation (OFI)

Issue: The Information Asset Register for FinSecure Bank's mobile application infrastructure was complete and accurate, but it had not been formally reviewed or updated in the last 11 months. The internal policy requires a semi-annual (6-month) review.

ISO Mapping: Annex A.5.9 (Inventory of Assets)

Risk Impact: Low operational risk. If asset reviews lag, newly spun-up software microservices or hardware assets might go undocumented, leading to blind spots in future security patching cycles.

Corrective Actions: Conduct a formal review and sign-off of the current Information Asset Register by the asset owners.

Preventive Control: Setup automated calendar reminders and email alerts triggered by the compliance platform 30 days before the 6-month review deadline expires...

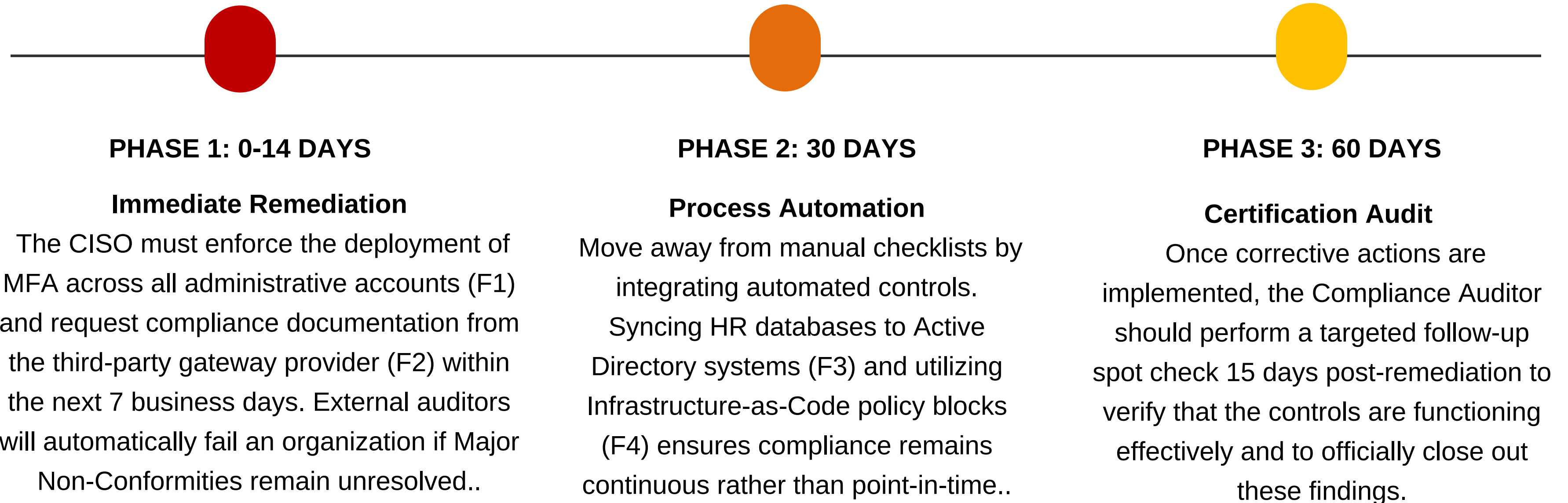
Priority Level: Low.

KEY FINDINGS SUMMARY

ID	Key Finding	ISO Mapping	Class	Risk Level
F1	MFA Failure	Annex A.8.5	Major Non-Conformity	High
F2	Incomplete Third-Party Supplier Risk Assessments	Annex A.5.19 & Clause 6.1.2	Major Non-Conformity	High
F3	Delayed IAM Offboarding	Annex A.7.6	Minor Non-Conformity	Med
F4	Data Classification	Annex A.5.12	Minor Non-Conformity	Med
F5	Outdated Asset Register Review Cycle	Annex A.5.9	Observation	Low

Recommendation Roadmap

To successfully pass the upcoming external ISO/IEC 27001 certification audit, FinSecure Bank's leadership must prioritize resources toward resolving the items detailed mentioned.



Discussion

Strategic Audit Insights & Operational Reflections

Transition from Static to Automated Governance

This internal audit highlighted that traditional, point-in-time checklist reviews are completely inadequate for a fast-evolving digital banking ecosystem. Gaps like delayed IAM offboarding (30–45 days) underscore that compliance must be engineered directly into operations via automation rather than manual human processes.

Cloud Infrastructure vs. Compliance Visibility

Our review of the AWS environment proved that strong technical infrastructure is easily undermined by loose configuration controls. Leaving root accounts without active Multi-Factor Authentication (MFA) and ignoring mandatory data classification metadata tags on S3 storage buckets exposes the bank to catastrophic exposure vectors.

The Weight of Local Regulatory Scrutiny

Operating in Malaysia means satisfying international ISO 27001 standards is only half the battle. For financial institutions, alignment with BNM RMiT directives means third-party vendor blind spots like missing contractually protected Right-to-Audit clauses on transaction APIs pose immediate operational and legal existential threats.

Value of Pre-Certification Assessments

Discovering two major non-conformities early prevents a definitive failure during the formal external certification audit. It allows the audit team to establish an assertive engineering roadmap to transition FinSecure Bank into a continuously secure state

Conclusion

Audit Metric Breakdown: 2 Major Non-Conformities
2 Minor Non-Conformities
1 Observation

Core Risk Vulnerability Focus: FinSecure Bank's most volatile operational exposure vectors reside within its privileged access governance boundaries and third-party payment gateway integration points.

Final Certification Readiness Status: FinSecure Bank is not currently positioned to successfully pass the formal external ISO/IEC 27001 certification audit. External accreditation bodies will trigger an automatic audit failure due to the unresolved Major Non-Conformities.

Authorization to Proceed: The compliance and technical teams are authorized to immediately initiate the 0–60 day remediation roadmap. Proceeding to the external certification audit phase is strictly conditional upon the technical deployment of app-based MFA enforcement and retroactive supplier security vetting.

× × × ×

Report Compiled By Keertennah Devi, Lead Auditor Lilian, Technical Auditor Nethra Compliance Auditor

THANK YOU

Confidential Internal Audit Report | FinSecure Bank

Visit Our Website
www.finsecurebank.com 

